

CENTINELA-AI

Arquitectura Omni-XDR, Gobernanza de IA & SOAR 2.0

Presentación Técnica y Ejecutiva de Profundidad (Basada en el Manual Técnico)

1. Resumen Ejecutivo y Origen

¿Por qué se desarrolló Centinela-AI?

Fragmentación de Herramientas

Tool Sprawl con 10-15 soluciones desconectadas genera silos de información, sobrecarga operativa (alert fatigue) y costos insostenibles.

Riesgos de IA (OWASP LLM Top 10)

El uso creciente de LLMs expone vectores no tradicionales: Prompt Injection, fuga de PII y ejecución de código no sandboxeado.

Brecha de Remediación (MTTR)

La detección toma minutos pero la remediación semanas. Centinela elimina esta brecha con parches automáticos y supervisión humana.

2. Propósito y Finalidad

¿Para qué sirve Centinela-AI en la organización?

Visibilidad Omnidireccional 360°

Centro neurálgico de ciberseguridad que audita activos físicos, virtuales, código fuente en GitLab, contenedores y endpoints de IA.

⚡ Operación Defensiva Autónoma (SOAR)

Respuesta automatizada ante incidentes con control estricto del usuario (Human-in-the-Loop) para mitigar amenazas en milisegundos.

Mapeo Normativo Continuo

Traducción automática de hallazgos técnicos a requisitos de ISO 27001, NIST SP 800-53, PCI-DSS v4.0, SOC 2 y GDPR.

3. Cobertura de Seguridad (6 Pilares)

¿Qué audita el sistema?

1. SAST & Clean Code

Motor AST nativo + Semgrep (SQLi, CMD Injection, SSRF, Secretos, ISO 25010).

2. SCA & Dependencias

Escaneo de paquetes npm/pip en vivo contra OSV.dev con análisis de alcanzabilidad.

3. Hardening & IaC

Checkov (Terraform/K8s), Dockerfiles no-root y CIS Benchmarks Linux SSH.

4. Gobernanza de IA

OWASP LLM Top 10 via Medusa-Security (Prompt Injection, fuga de PII).

5. Monitoreo Runtime

Wazuh EDR, Zeek NDR (conn.log), eBPF Tracing, Authentik ITDR.

6. Auto-Fix DevSecOps

Parcheo determinístico y asistido por IA con integración a GitLab MR.

4. Estándares y Marcos Normativos Cubiertos

Mapeo automático de auditoría y cumplimiento corporativo

STRIDE Threat Model

Spoofing (JWT RS256/Ed25519 vs HS256), Tampering, Repudiation (bitácora inmutable), Information Disclosure, DoS y Elevation of Privilege.

ISO/IEC 25010 & ISO 27001

Calidad de software (Complejidad Cognitiva < 15) y Controles A.5.15 (Acceso), A.8.9 (Configuración), A.8.24 (Criptografía), A.8.28 (Codificación Segura).

NIST SP 800-53 & PCI-DSS v4.0

Controles AC-3, CM-6, SI-10, AU-3, SC-8 / Requerimientos 2.2 (Hardening), 6.5.1 (Injection Flaws) y 10.2 (Auditoría Automatizada).

SOC 2 Type II & GDPR

Criterios CC6.1 (Acceso Lógico), CC6.8 (Hardening), CC7.2 (Monitoreo) y Cumplimiento Art. 30/32 (Registro de Actividades y Cifrado PII).

5. Taxonomía de Hallazgos y Amenazas Cubiertas

Identificación y trazabilidad de vectores de ataque por motor

ZAP-NNNNN

Plugin ID oficial OWASP ZAP (ej: ZAP-10015 Incomplete Cache-Control, cabeceras ausentes, XSS).

SCA-CVE-YYYY-NNNNN

Vulnerabilidades en dependencias sincronizadas en vivo con OSV.dev (ej: Express, PyYAML).

CODE / CMD / SQL / SSRF

Reglas del motor SAST nativo (ej: CODE-INJECTION-EVAL, concatenación de SQL dinámico).

DOCKER / IaC

Hardening de infraestructura (ej: DOCKER-MISSING-NON-ROOT-USER, buckets S3 públicos).

STD-STRIDE / ISO25010

Violaciones arquitectónicas y calidad de software (ej: STD-STRIDE-JWT-INSECURE-ALG).

CTI-IOC / ITDR / eBPF

Vectores runtime (Password Spraying en Authentik, C2 IPs activas de Feodo Tracker, syscalls Linux).

6. Correlación de Riesgo (CRS) y Motor IA

Cálculo de criticidad y resiliencia multi-proveedor de LLM

Centinela Risk Score (CRS)

Puntuación 0-100 por hallazgo. Combina la severidad CVSS con probabilidad de explotación real (EPSS de FIRST.org en vivo), CISA KEV (ataques confirmados en el mundo) y la criticidad del activo.

Cadena Multi-Proveedor LLM

Cadena de resiliencia con fallback automático en cada llamada:
Groq → Google Gemini → NVIDIA
NIM → OpenRouter → Motor
Heurístico Determinístico.
Garantiza disponibilidad constante si una API agota cuota.

Validación Estricta de Parches

La IA genera diffs unificados (``git apply``) o scripts Bash. Centinela valida que la respuesta no sea texto de relleno (``... script provisto``); si la calidad es baja, cae automáticamente al motor determinístico.

7. Funcionamiento del SOAR 2.0 y Remediación

Flujo de ejecución defensiva automatizada con Human-in-the-Loop

1. Evaluación de Confianza

Si la confianza del parche es $\geq 95\%$ (Virtual Patching Nginx / Revocación Authentik), se ejecuta respuesta inmediata. Si es $< 95\%$, requiere aprobación 1-click.

2. Remediación en Servidores

Sentinel se autentica vía Vault (credenciales SSH/sudo dedicadas `NOPASSWD` acotadas) y ejecuta Playbooks de Ansible. Si el comando falla, el estado se marca `FAILED`.

3. Remediación en GitLab

Sentinel clona el repositorio, aplica el diff unificado en una rama `centinela-fix/\*` y abre un Merge Request formal con detalles normativos. NUNCA hace push directo a main.

4. Trazabilidad Inmutable

Todo evento de remediación se registra en PostgreSQL y auditoría STRIDE, garantizando no-repudio y visibilidad completa para los auditores de seguridad.

8. Beneficios Organizacionales

¿Qué aporta su uso a cada rol en la empresa?

Para la Dirección / C-Level

- Reducción radical del riesgo de brechas.
- Ahorro directo por consolidación de herramientas.
- Reportes ejecutivos de cumplimiento (ISO/NIST/PCI).

Para Líder de Equipo / SOC

- Tablero unificado Single-Pane-of-Glass.
- Priorización basada en riesgo real (EPSS/KEV).
- Quality Gates para pipelines CI/CD.

Para el Equipo de Desarrollo

- Fricción cero: Parches mediante MRs formales.
- Explicaciones didácticas en cada MR.
- Detección temprana en el ciclo DevSecOps.

9. Estrategia de Comercialización Futura

¿Cómo monetizar Centinela-AI como Producto B2B?

SaaS Enterprise (Cloud)

Suscripción mensual/anual basada en la cantidad de activos monitoreados (repositorios, servidores, contenedores).

Enterprise On-Premise

Licenciamiento anual para sectores regulados (Banca, Gobierno, Salud) con despliegue local o Air-Gapped.

Partner MSSP Program

Modelo Multitenant para consultoras de ciberseguridad que ofrecen servicios SOC/DevSecOps gestionados.

CONCLUSIÓN Y PRÓXIMOS PASOS

Centinela-AI no solo protege la infraestructura actual de la organización reduciendo costos operativos, sino que constituye un activo tecnológico estratégico con alto valor comercial B2B.

Solicitamos la aprobación de los Directivos para avanzar en la Fase 2 del desarrollo:

1. Conectores nativos multi-nube (AWS, GCP, Azure)
2. Arquitectura Multi-Tenancy para comercialización SaaS
3. Proceso de certificación SOC 2 Type II e ISO 27001